USER DOCUMENTATION

Gadaa Istar Export E-Commerce Platform

User Guide — Storefront & Admin Back-Office

A practical guide to how the Gadaa Istar hybrid B2B + B2C platform is used in day-to-day operations by shoppers, wholesale buyers, and back-office staff. Includes an appendix on common misuse scenarios and user-related risks.

DOCUMENT
User Guide (v1.0)

PLATFORM
gedaaistar.et · admin.gedaaistar.et

ISSUED
August 2026

Document information

Field	Value
Document title	Gadaa Istar — User Guide (Storefront & Admin Back-Office)
Version	1.0
Issued	August 2026
Product	Gadaa Istar Export E-Commerce Platform
Operator	Gadaa Istar Business Group S.C.
Primary URL	https://gedaaistar.et/
Admin URL	https://admin.gedaaistar.et/
Payment processor	CyberSource Secure Acceptance Hosted Checkout & Mastercard Payment Gateway Services (MPGS)
Compliance	PCI DSS SAQ-A, Ethiopian VAT (ERCA)
Audience	Retail shoppers (B2C), wholesale buyers (B2B), and administrative staff
Purpose	Describe how the system is used in practice; support the identification of misuse scenarios and user-related risks

HOW TO READ THIS GUIDE

This document is organised into two parts. **Part I** covers the public storefront (gedaaistar.et) as used by customers. **Part II** covers the admin back-office (admin.gedaaistar.et) as used by staff. The final appendix summarises misuse scenarios and user-related risks that follow from the workflows described earlier.

© Gadaa Istar Business Group S.C.

Table of contents

I. About this guide
1. Purpose & scope
2. Intended audience
3. Conventions used

II. Platform overview
1. What Gadaa Istar sells
2. User roles
3. Application URLs
4. Supported browsers & devices
5. Languages & currencies

III. Storefront user guide (customers)
1. Getting started & global navigation
2. Home page
3. Browsing the catalog
4. Product details & variants
5. Wishlist
6. Shopping cart
7. Creating an account (B2C and B2B)
8. Email verification
9. Signing in and out
10. Recovering your password
11. Your account portal
12. Checkout & payment
13. After payment: return, retry, cancel
14. Requesting a quote (B2B)
15. Tracking an order (public)
16. Static pages (About, Contact, FAQ, Legal)

IV. Admin back-office user guide (staff)
1. Signing in & multi-factor authentication
2. Dashboard
3. Notifications
4. Products
5. Price lists
6. Shipping methods
7. Orders & refunds

© Gadaa Istar Business Group S.C.

8. Quotes
9. Customers
10. Customer groups
11. Coupons
12. CMS pages & banners
13. Admin users & MFA reset

V. Appendix A — Misuse scenarios & user-related risks
VI. Appendix B — Glossary
VII. Appendix C — URL & keyboard reference

© Gadaa Istar Business Group S.C.

1. About this guide

1.1 Purpose & scope

This document is a practical user guide for the Gadaa Istar Export E-Commerce Platform. It describes how the deployed system at gedaaistar.et and the back-office at admin.gedaaistar.et are used in practice by end-users and staff.

The guide covers every user-facing feature that a customer or an administrator can reach through the browser. It does **not** cover developer topics such as source-code layout, deployment pipelines, or infrastructure configuration — those live in the developer `README.md` and the internal engineering plan.

A dedicated appendix at the end (Appendix A) enumerates common misuse scenarios and user-related risks that follow from the workflows described earlier. That appendix is intended to feed the platform's risk register and privacy / security review.

1.2 Intended audience

- **Retail (B2C) customers** browsing gedaaistar.et and placing personal orders.
- **Wholesale (B2B) buyers** from businesses that hold an approved account and use tiered pricing and quote requests.
- **Customer-service staff** and **fulfilment staff** using the admin back-office to manage orders, quotes, refunds, and customers.
- **Catalog managers** and **marketing staff** managing products, pricing, coupons, and CMS content.
- **Super-administrators** managing admin accounts, MFA, and system-level controls.
- **Auditors and risk / compliance reviewers** using the misuse-scenarios appendix.

1.3 Conventions used

- `Monospace` is used for URLs, file names, field values, and error codes.
- `Enter` and other keys are shown in a boxed style.
- Verbatim UI text is written in "quotes" to match the button or label the user actually sees.
- Callout boxes appear throughout:
  - **Tip** — navy border, non-critical usage hints.
  - **Warning** — red border, actions with wider impact.
  - **Risk** — dark-red border, misuse and abuse indicators.
- Storefront routes are shown as paths under `gedaaistar.et` (e.g. `/checkout`). Admin routes are shown as paths under `admin.gedaaistar.et` (e.g. `/orders`).

© Gadaa Istar Business Group S.C.

2. Platform overview

2.1 What Gadaa Istar sells

Gadaa Istar is a hybrid **B2B + B2C** export platform for Ethiopian coffee (raw and processed) and specialty agricultural products. The catalog is organised into seven categories:

- Raw Green Coffee
- Roasted Coffee
- White Products (e.g. white sesame, pulses)
- Spicy Products (chili, spices)
- Oil Seed
- Livestock
- Mining

2.2 User roles

The platform recognises the following user categories:

Role	Where they log in	What they can do
Guest visitor	— (no login)	Browse catalog, add to cart, add to wishlist, look up an order using invoice + email.
B2C customer "Retail" (RETAIL group)	gedaaistar.et » Sign in	Everything a guest can do, plus place orders, save addresses, view order history.
B2B customer Wholesale (WHOLESALE_T1, WHOLESALE_T2, VIP)	gedaaistar.et » Sign in (after admin approval)	Everything a B2C customer can do, plus request quotes, buy at tiered wholesale prices with MOQ multipliers.
ADMIN Back-office staff	admin.gedaaistar.et	Manage products, orders, quotes, customers, price lists, shipping, coupons, CMS. Most read/write endpoints require this role.
SUPERADMIN	admin.gedaaistar.et	Everything an ADMIN can do, plus create / disable other admin accounts, reset another admin's MFA secret, and delete customer groups.

2.3 Application URLs

Environment	Storefront	Admin
Production	`https://gedaaistar.et/`	`https://admin.gedaaistar.et/`

2.4 Supported browsers & devices

The storefront is built as a modern responsive application (Angular with server-side rendering) and is intended to work on:

© Gadaa Istar Business Group S.C.

- The latest two versions of Chrome, Edge, Firefox, and Safari.
- Mobile Safari on iOS 15+ and Chrome on Android 11+.

The admin back-office is intended for desktop use in a modern browser. JavaScript and cookies (for session state) must be enabled. A stable internet connection is required.

2.5 Languages & currencies

The storefront supports three interface languages, selectable from the header:

- **English** — default
- **Amharic** (አማርኛ)
- **Afaan Oromoo**

Prices can be displayed in **USD** (default for English) or **ETB** (default for Amharic / Afaan Oromoo). The user's choice is saved in the browser so it persists across visits.

> **WHERE PREFERENCES LIVE**
>
> Language, currency, wishlist contents, and the guest-cart session key are all stored in the browser's local storage. Clearing browser data will reset them.

© Gadaa Istar Business Group S.C.

PART I

Storefront user guide

How retail (B2C) shoppers and wholesale (B2B) buyers use gedaaistar.et — from first visit to placed order to quote negotiation.

© Gadaa Istar Business Group S.C.

3. Storefront — getting started

3.1 Global navigation

Every page on the storefront shares the same header and footer.

HEADER

- **Brand block:** Gadaa Istar logo, wordmark, and the tagline "Business Group S.C.". Clicking it returns to the home page.
- **Search box:** "Search products…". Pressing `Enter` submits and routes to `/shop?q=…`.
- **Language switcher:** dropdown with English (default), Amharic, and Afaan Oromoo.
- **Currency toggle:** two buttons, **USD** and **ETB**.
- **Sign in / Sign up** buttons when signed-out; a greeting chip ("Hi, *name*") and a "Sign out" button when signed-in.
- **Wishlist** heart icon with a live count badge.
- **Cart** icon with a live count badge.

PRIMARY NAVIGATION BAR

Under the header there is a row of category links (Raw Coffee, Roasted Coffee, White Products, Spicy Products, Oil Seed, Livestock, Mining) plus **Our Story** (/about), **Contact Us** (/contact), and **Track Order** (/track-order).

FOOTER

- **Column 1 — Gadaa Istar:** short description and motto "We are in you, you are in us."
- **Column 2 — Shop:** the seven category links.
- **Column 3 — Company:** About, Contact, Track Order, Wishlist, FAQ, and any published CMS pages.
- **Column 4 — Legal:** Terms of Service, Privacy Policy, Shipping & Returns.
- **Bottom bar:** copyright, "All rights reserved.", and card-scheme badges (VISA, MASTERCARD, AMEX, JCB).

> **TIP — KEYBOARD-FRIENDLY SEARCH**
>
> You can search from anywhere on the site by clicking the search box at the top and typing a keyword; press `Enter` to open the shop with that filter applied.

4. Home page

URL: `/`

The home page opens with the following blocks (top to bottom):

1. **Marketing banners.** A rotating strip of banners maintained by the marketing team through the admin back-office. Each banner is optionally clickable.
2. **Hero section.** Fixed content:
   - Eyebrow: "Direct from origin · Ethiopia"

- Headline: "From Ethiopian highlands to the world's table."
- Two calls to action: "Explore products" (opens `/shop/raw-coffee`) and "Contact & export inquiries" (opens `/contact`).
- Trust badges: Organic-ready, Fairtrade-friendly, PCI DSS secure checkout, Multi-currency (USD · EUR · GBP).

3. **Stats strip.** Static facts: 7 product categories, 100% traceable origin, 30+ destination countries, Addis Ababa quality-check facility.
4. **Featured products carousel.** Auto-advances every 5 seconds. Each card shows an image, name, short description, price, and an "In stock" or "Sold out" badge. A "View all" link opens the full catalog.
5. **Category tiles.** Seven clickable tiles — one per category — that jump to `/shop/<category>`.
6. **Trust section.** Four reassurance blocks: PCI DSS SAQ A payments, global shipping (DHL & FedEx retail), VAT-compliant invoicing, and B2B / B2C accounts.

5. Browsing the catalog

URL: `/shop` or `/shop/<category>`

5.1 Filtering and searching

- The search bar at the top of the shop is debounced — typing pauses for 300 ms before the results refresh.
- An X button clears the current search.
- The **category rail** below the header lets you switch between All and any of the seven categories.
- The URL updates as you filter, so the filtered page is bookmarkable and shareable.

5.2 The product grid

Each card in the grid shows:

- Primary product image (or a placeholder icon).
- Category label.
- Product name.
- Short description.
- Price. A strikethrough original price is shown when a discount applies, along with a "Save X%" badge.
- An "Out of stock" badge if the item is unavailable.

The grid paginates 12 items at a time. "Previous" and "Next" buttons and a "Page X of Y" indicator sit under the grid.

> **EMPTY RESULTS**
> If no products match, the shop shows either "No results found" (when a search term is active) or "No products yet" (for an empty category). If the API cannot be reached, the shop shows "Could not load the catalog. Please try again." with a retry button.

© Gadaa Istar Business Group S.C.

6. Product details

URL: `/products/<slug>`

6.1 Layout

1. **Breadcrumb**: Home » Shop » Category » Product name.
2. **Media gallery**: a hero image plus a thumbnail strip. Sale and Out-of-stock badges overlay the hero.
3. **Product info**: category, name, short description, and the resolved price (with strikethrough if a discount / tier price applies).
4. **Variant selector**: a radio list of variants, each showing its attributes, stock ("X available" or "Out of stock"), and price override if different.
5. **Product facts**: origin country (displayed as "Ethiopia" when the ISO code is ET), unit weight, HS code, and minimum order quantity.
6. **Quantity + Add to cart** panel.
7. **Wholesale price ladder** — for B2B accounts only. A table of "Order at least" and "Unit price".
8. **About this product**: full description.
9. **Packaging**: packaging notes if the product ships in a specific pack.

6.2 Adding to cart

1. If the product has variants, choose one first. If you don't, the site shows: "Please select a variant first."
2. Adjust the quantity with the − and + buttons. The minimum is set by the product's minimum order quantity (MOQ), and B2B customers may see a larger effective MOQ because of their group multiplier.
3. Click **Add to cart**. While the request is in flight the button shows "Adding…". A green confirmation flash "Added to cart" appears for 3 seconds.
4. The heart icon at the top-right of the panel toggles the product in your wishlist.

> **SERVER-SIDE VALIDATION**
>
> Backend errors are shown verbatim: `INSUFFICIENT_STOCK` (someone else bought the last units first), `MIN_ORDER_QUANTITY` (quantity below the effective MOQ), or `PRODUCT_NOT_PURCHASABLE` (draft or archived product). Adjust the quantity or variant and try again.

7. Wishlist

URL: `/wishlist`

The wishlist is a purely client-side feature that stores product slugs in your browser's local storage. It works without signing in and persists across visits on the same browser.

7.1 What you see

- Header: "Your wishlist" with an item count.
- Product cards showing the image, name, SKU, price, an "Out of stock" badge when applicable, an **Add to cart** button (disabled if out of stock), and a remove-heart button.

© Gadaa Istar Business Group S.C.

- If a saved item has been removed from the catalog, the card is replaced with "Product unavailable" and a "Remove" button.
- Empty state: "No saved items yet. Tap the heart icon on any product to save it for later."

> **THE WISHLIST DOES NOT SYNC BETWEEN DEVICES**
> Wishlists live only in the local browser. Signing in does not migrate them, and clearing browser data will empty the wishlist.

8. Shopping cart

URL: `/cart`

8.1 Cart contents

Each line in the cart shows:

- Product thumbnail and name (link back to the product page).
- Variant name and SKU.
- Unit price. When the storefront detects that the catalog price has changed since the item was added, a "Price updated" note appears.
- An "Only X in stock" warning if the requested quantity exceeds available stock.
- A quantity stepper (− and +) and a live line total.
- A **Remove** button.

8.2 Order summary

- Item count (number of SKUs and total units).
- Subtotal.
- Tax and Shipping shown as "Calculated at checkout".
- **Proceed to checkout** button. If the user is a guest, this redirects to `/login?next=/checkout`.
- **Request a quote** button — visible only if the user is signed in and the cart is non-empty. Recommended for B2B buyers who want to negotiate.
- The reassurance line "Secure payment via CyberSource".

8.3 Empty cart

An empty cart shows a friendly empty state and a link back to the catalog. Clicking "Empty cart" asks for confirmation before removing everything.

> **GUEST CARTS ARE PRESERVED ON SIGN-IN**
> When a guest signs in or registers, any items already in the guest cart are merged into the customer's cart automatically. The guest session key lives in local storage under `gi-guest-session-key`.

© Gadaa Istar Business Group S.C.

9. Creating an account

URL: `/register`

9.1 Choosing an account type

Registration opens with a big radio choice:

- **Personal (retail)** — "Shop retail packs; instant checkout."
- **Business (wholesale)** — "Tiered pricing for bulk orders."

9.2 Registration fields

Field	Required	Rules
First name	Yes	Max 120 characters.
Last name	Yes	Max 120 characters.
Company name	Only for B2B	Max 255 characters.
Company TIN	Optional (recommended for B2B)	Needed for VAT-compliant invoices.
Email	Yes	Valid email format; must not already exist.
Password	Yes	Minimum 8 characters.
Phone	Optional	—
Preferred currency	Yes	USD or ETB.

9.3 Common errors

- "Company name is required for business accounts."
- "Please enter a valid email."
- "Password must be at least 8 characters."
- "An account with this email already exists. Try signing in instead."

> **B2B ACCOUNTS ARE NOT ACTIVE IMMEDIATELY**
>
> Choosing **Business (wholesale)** creates the account in **Pending B2B approval** status. The buyer must wait for an admin to verify the business licence out-of-band and approve the account before wholesale pricing and quotes are available.

10. Email verification

10.1 "Check your inbox" page

URL: `/verify-email/pending`

After registration, the storefront shows the "Check your inbox" page: "We've sent a confirmation link to *your email*. Click it to activate your account. The link expires in 60 minutes." Two actions are available:

© Gadaa Istar Business Group S.C.

Resend the email and **Back to home**.

10.2 Confirming the token

URL: `/verify-email/<token>`

Clicking the link from the email opens a page that goes through three states:

- **Verifying** — a spinner and "Confirming your email…".
- **Success** — "Email confirmed" and two buttons, **Start shopping** and **Go to my account**.
- **Error** — "We couldn't verify your email" with the reason ("Missing verification token in the URL.", "That verification link is invalid or has already been used.", or "That link is no longer valid — request a new one."). A **Request a new link** action is offered.

11. Signing in and out

11.1 Sign in

URL: `/login`

- Fields: Email (required, valid format), Password (required, min 8 characters).
- Button: "Sign in". While loading it shows "Signing in…".
- Links: "Forgot your password?" and "New to Gadaa Istar? Create an account".
- If the URL contains `?reset=1` or `?passwordChanged=1`, a green banner confirms the earlier action.
- Error messages are explicit: "The email or password you entered is incorrect.", "Your account has been suspended. Please contact support.", "Your B2B account is still awaiting approval.", "Could not reach the server. Please check your connection."
- On success the browser is redirected to `?next=` (if present) or `/account`.

11.2 Sign out

Click "Sign out" in the top bar. This clears the session on the server (revokes tokens) and locally. You are returned to the home page.

> **CHANGING A PASSWORD SIGNS OUT EVERY DEVICE**
> Using the "Change password" flow (below) invalidates every active session on every browser and device you are signed in on.

12. Recovering your password

12.1 Forgot password

URL: `/forgot-password`

Enter the email address on your account and click **Email me a reset link**. The screen always shows the same reassurance message ("If *email* matches an account, we've just sent a reset link. It's valid for the next 30 minutes.") whether or not the address is on file — this prevents enumeration of registered emails.

© Gadaa Istar Business Group S.C.

12.2 Reset password

URL: `/reset-password/<token>`

- Enter and confirm a new password (8–128 characters).
- Click **Save new password**.
- On success you see "Password updated" and after 2.5 seconds you are redirected to `/login?reset=1`. All other sessions have been revoked.
- Errors: "Password must be 8–128 characters.", "Both passwords must match.", "That reset link is invalid or has already been used. Request a new one.", "That reset link is no longer valid — request a new one."

© Gadaa Istar Business Group S.C.

13. Your account portal

URL: `/account` (sign-in required)

The customer portal is organised into tabs down the side or across the top:

- Profile
- Addresses
- Orders
- Transactions (visible only to select accounts)
- Quotes

13.1 Profile

URL: `/account` (default tab)

The Profile tab has three modes:

VIEW MODE

- Avatar, full name, email address, and a status badge: **Verified** (green) or **Pending verification** (yellow).
- Account type tag: **Business account** or **Retail account**.
- Read-only fields: Email, First name, Last name, Phone, Company (B2B), Tax ID (B2B), Preferred currency.
- Two actions: **Edit profile** and **Change password**.

EDIT MODE

- Editable fields: First name, Last name, Phone, Preferred currency. B2B users additionally see Company name, Tax ID (TIN), VAT number.
- Hint: "Leave a field blank to keep its current value."
- Buttons: **Save changes** or **Cancel**.
- On success: "Profile updated."

CHANGE PASSWORD MODE

- Fields: Current password, New password (8–128), Confirm password.
- Warning: "Changing your password signs you out of every device. You'll return to the sign-in page after we save the change."
- Errors: "Current password is incorrect.", "New password and confirmation do not match.", "Too many attempts. Please wait a few minutes before trying again."

13.2 Address book

URL: `/account/addresses`

The address book lists every saved shipping and billing address. Each card shows:

- Address type label: "Shipping & Billing", "Shipping only", or "Billing only".
- A "Default" star badge on the default address.
- Full name, company, address lines, and phone.
- Actions: **Make default** (if not already default), **Edit**, **Delete**.

© Gadaa Istar Business Group S.C.

The **Add address** / **Edit** form asks for:

Field	Required	Rules
Full name	Recommended	Max 200 characters.
Company	Optional	Max 255 characters.
Street address	Yes	Max 255 characters.
Apt / floor / unit	Optional	Max 255 characters.
City	Yes	Max 120 characters.
Region / state	Optional	Max 120 characters.
Postal code	Optional	Max 32 characters.
Country code	Yes	Two-letter ISO code (uppercase), e.g. `ET`, `DE`, `US`.
Phone	Optional	Max 64 characters.
Use for	Yes	Shipping & Billing, Shipping only, or Billing only.
Default	Optional	Set as my default <type> address.

13.3 Orders

URL: `/account/orders`

Each row shows the invoice number (link), the placement date and item count, a colour-coded status badge, and the grand total. The list paginates (20 orders per page) with a **Load more** button.

ORDER DETAIL

URL: `/account/orders/<uuid>`

- **Header:** invoice number, "Order details", placement date, status badge.
- **Payment gateway warning**: shown only when the payment gateway is not configured in this environment.
- **Items:** thumbnails, names, SKUs, quantities, unit prices, and line totals.
- **Totals:** Subtotal, Discount (with the applied coupon code), Tax, Shipping (with the method's name), and Total.
- **Addresses:** "Ship to" and "Bill to" cards.
- **Status timeline:** a chronological list of status changes with source (webhook / api) and any admin notes attached to the transition.
- **Actions when the order is Pending payment:** a payment-method selector, "Continue payment" (redirects to CyberSource / MPGS), "I've paid — refresh status", and **Cancel order** (with confirmation).

13.4 Transactions

URL: `/account/transactions`

Available to a specific superuser account only. Lists every transaction across orders in one long paginated table. Ordinary customers do not see this tab.

© Gadaa Istar Business Group S.C.

13.5 Quotes

URL: `/account/quotes`

Same layout as the Orders list, but shows quote requests with a quote number and a "Valid until" date when applicable.

QUOTE DETAIL

URL: `/account/quotes/<uuid>`

The page shows the proposed pricing supplied by the sales team, plus any messages ("Message from our team:"). Depending on the quote's status, an **Accept quote** button appears. Status banners cover all end states:

- "You've accepted this quote. Our team will convert it to an order shortly."
- "This quote has been converted to an order."
- "This quote request was rejected."
- "This quote has expired."

© Gadaa Istar Business Group S.C.

14. Checkout & payment

URL: `/checkout` (sign-in required)

Checkout is a single page composed of five stacked panels. Every step keeps its state as the user scrolls up and down.

14.1 Ship to

- Saved addresses appear as radio-selectable cards. The default address is preselected.
- A **Default** badge marks the current default.
- Clicking **Add a new address** opens the inline address form (same field set as in Section 13.2).
- Country code is validated: "Use a 2-letter code, e.g. ET, US, DE."

14.2 Shipping method

- While shipping options load: "Calculating shipping options for your cart…".
- Once loaded, each option shows its name, description, ETA ("min–max business days"), and cost.
- The current weight the price is based on is shown as "Priced for your cart (X kg)".
- If no options exist for the destination, checkout still allows placement but shipping is billed at zero.

14.3 Coupon code

- Enter a code (max 64 characters) and click **Apply**.
- An applied coupon shows the code, description, discount (percentage or amount), and any "free shipping" flag. A **Remove** button clears it.
- The discount preview line updates immediately on the summary.

14.4 Payment method

A radio list of payment methods offered by the platform. The default is Mastercard Payment Gateway (MPGS). Each option shows a name and a short description.

14.5 Notes

An optional free-text field (max 1000 characters) for the fulfilment team.

14.6 Order summary and placement

The right-hand summary shows every cart line with thumbnails, quantities and prices, and the running totals: Subtotal, Tax ("Applied at payment"), Shipping (with method name), Discount (with the coupon code), and an estimated total. The button reads **Continue to secure payment**. Underneath the button: "You'll be redirected to Mastercard / CyberSource".

© Gadaa Istar Business Group S.C.

> **WHAT HAPPENS WHEN YOU CLICK "CONTINUE TO SECURE PAYMENT"**
> The platform creates the order in **Pending payment** status and submits an auto-post form that hands the browser to CyberSource or MPGS. Card details are entered on the payment processor's page — the storefront never receives them. This is what makes the platform PCI DSS SAQ-A compliant.

15. After payment

15.1 "Payment confirmed" page

URL: `/checkout/return`

Depending on the gateway's response the page shows one of several states:

- **Loading:** "Finalising your payment…".
- **Pending:** "Waiting for your bank to confirm…". The page automatically re-checks the order status every 3 seconds for up to 30 seconds.
- **Success:** "Thank you — your order is confirmed!" with the invoice number, status, total, and paid date. Two actions: **View order details** and **Keep shopping**.
- **Cancelled:** "Payment didn't go through" — order cancelled, no charge.

15.2 "Payment cancelled" page

URL: `/checkout/cancel`

- **If the order is still Pending payment** the page shows "Payment paused" with two buttons: **Retry payment** (auto-posts to the gateway again) and **Cancel this order** (asks for confirmation, releases the reserved stock).
- **If the order is already Cancelled** the page shows "Order cancelled" and offers **Keep shopping** or **View order**.

16. Requesting a quote (B2B)

Wholesale buyers can turn their cart into a quote request instead of placing an order.

1. Add products to the cart the normal way, respecting the tier's MOQ multiplier.
2. Open `/cart`.
3. Click **Request a quote** in the summary panel. The button is only visible if you are signed in and the cart is non-empty.
4. You are redirected to the new quote's detail page under `/account/quotes/<uuid>`. The quote is now in `SUBMITTED` status; the sales team is notified.
5. Later, the customer returns to `/account/quotes`, opens the quote once the status is `SENT`, reviews the proposed pricing and validity, and clicks **Accept quote**. The sales team then converts the accepted quote into a live order (paid separately).

© Gadaa Istar Business Group S.C.

> **QUOTE LIFECYCLE AT A GLANCE**
>
> `DRAFT` → `SUBMITTED` → `UNDER_REVIEW` → `SENT` → `ACCEPTED` → `CONVERTED`. A quote can be `REJECTED` from `SUBMITTED` or `UNDER_REVIEW`, or `EXPIRED` if it passes its validity window.

17. Tracking an order (public)

URL: `/track-order`

Any visitor — signed in or not — can look up an order:

1. Enter the order reference (e.g. `GI-2026-00003`) or its UUID.
2. Enter the email that was used at checkout.
3. Click **Track order**.

When the email matches the order the page reveals the invoice, placed and paid timestamps, shipping method, item list, grand total, and a status history. If nothing matches, the friendly message *"No matching order found. Check that the order reference and email are correct. If you placed the order as a guest, use the email you entered at checkout."* is shown.

> **RISK — ENUMERATION ATTEMPTS**
>
> Because the tracking endpoint accepts any invoice number, malicious users may attempt to guess order references. The platform only reveals order details when both the reference **and** the correct email are supplied, so no confidential information leaks — but repeated failed lookups may still indicate scraping and should be monitored via server logs.

18. Static pages

URL: `/pages/<slug>` (shortcuts: `/about`, `/contact`)

Content pages such as About Us, Contact, FAQ, Terms of Service, Privacy Policy, and Shipping & Returns are managed as CMS entries in the back-office. If a slug does not resolve, the page shows "Page not found." with a "Back to home" link.

© Gadaa Istar Business Group S.C.

PART II

Admin back-office user guide

How back-office staff use admin.gedaaistar.et — sign-in, catalog management, order and quote handling, customer approvals, coupons, CMS content, and admin user administration.

© Gadaa Istar Business Group S.C.

19. Signing in to the back-office

URL: `https://admin.gedaaistar.et/login`

Every admin session begins with a two-step sign-in:

1. Email and password on the login page.
2. A time-based one-time code (TOTP) on the MFA page.

19.1 Login

- Fields: Email (required), Password (required, min 8, show/hide toggle).
- Helper text: "You'll be asked for a 6-digit code from your authenticator app after this step."
- Button: "Continue" (shows "Signing in…" while loading).
- Link: "Forgot password?"

Common error messages:

- "That email or password is incorrect. Please try again."
- "This admin account is disabled. Contact a super-admin."
- "Please check the highlighted fields and try again."

19.2 Multi-factor authentication (MFA)

URL: `/verify-mfa`

FIRST SIGN-IN — ENROLMENT

The first time an admin signs in, the page shows:

- Heading: "Set up two-factor authentication".
- Explanation: "This is your first sign-in as *email*. Scan the QR code below with an authenticator app (Google Authenticator, Authy, 1Password, …), then enter the 6-digit code to finish."
- A 220×220 px QR code generated client-side.
- An "Or enter the code manually:" block with the Base32 secret, issuer, and account name.
- Algorithm info: "SHA-1 · 6 digits · 30-second window".
- Input: "Authentication code" (6 digits).
- Buttons: **Finish setup** and **Cancel and sign in again**.

RETURNING SIGN-INS

- Heading: "Enter your 6-digit code".
- Message: "Signed in as *email*. Open your authenticator app and enter the current code to continue."
- Input + button: "Verify & sign in".

Common MFA errors:

- `MFA_INVALID_CODE`: "That code was not accepted. Try the current 6-digit code from your authenticator."
- `INVALID_TOKEN` / `TOKEN_EXPIRED`: "Your sign-in window expired. Please sign in again."
- `MFA_NOT_INITIALIZED`: "No MFA secret on file. Please sign in again to start enrollment."

© Gadaa Istar Business Group S.C.

DO NOT SKIP MFA ENROLMENT

Once you finish MFA setup, save a copy of the recovery information (secret or the app's export) in a secure location. If you lose your authenticator device, only a super-admin can reset your MFA.

© Gadaa Istar Business Group S.C.

20. Dashboard

URL: `/dashboard`

The dashboard is the landing page for every admin after sign-in. It provides real-time operational visibility.

20.1 KPI tiles

Tile	Meaning
Open orders	Orders awaiting fulfilment.
Pending B2B approvals	New wholesale accounts waiting for review.
Products live	Products in the storefront catalog.
Revenue this month	Paid orders in the current calendar month.
Low-stock items	Products at or below their restock threshold.
Active coupons	Currently redeemable coupons.
Abandoned orders	Orders that were pending payment for more than one hour.
Revenue today	Today's revenue plus the day's order count.

20.2 Other blocks

- **Revenue trend card** — today's revenue vs yesterday, this month vs the previous 30 days, plus a 7-day bar chart.
- **Order status breakdown** — horizontal bar chart showing count and percentage per status.
- **Recent orders** — the last handful of orders (Invoice, Customer, Status, Items, Total, Date). Rows link straight to the order detail.
- **Low-stock alerts** — product name, variant, SKU, available quantity, and restock threshold.

> **RECOVERY FROM ERRORS**
>
> If any block fails to load the dashboard shows "Could not load dashboard stats." A "Last updated *timestamp*" footer confirms when the numbers were last refreshed.

21. Notifications

The bell icon in the top-right of every admin page shows a badge with the total number of items needing attention. Clicking it opens a dropdown with three shortcuts:

- **Open orders** → jumps to `/orders`.
- **Low stock items** → jumps to `/products`.
- **Pending B2B approvals** → jumps to `/customers`.

The counts refresh automatically every 60 seconds.

© Gadaa Istar Business Group S.C.

22. Products

URL: `/products`

22.1 Product list

- **Filters**: a "Search by SKU, name, or slug…" box; category chips (All, Raw Coffee, Roasted, White Products, Spicy Products, Oil Seed, Livestock, Mining); a status dropdown (Any status, Draft, Active, Archived).
- **Table columns**: thumbnail, Name (with slug), SKU, Category, Status (pill), Base price, Available, Updated.
- **Empty state**: "No products match your filters. Try clearing filters or check that the product exists in the database."
- **New product** button opens the creation form.

22.2 Product editor

URL: `/products/<id>/details`

The editor is organised into five tabs.

DETAILS

Field	Rules
SKU	Uppercase letters, digits, dot, dash, underscore. Max 64. Cannot be changed after creation.
Slug	Lowercase kebab-case, max 200 (e.g. `yirgacheffe-green-500g`).
Name	Required. Max 255.
Short description	Max 500.
Description	Long text.
Category	Required. One of the seven categories.
Status	DRAFT, ACTIVE, or ARCHIVED.
HS code	Max 32.
Origin country	ISO-2 code. Default ET.
Base currency	ISO-3 code. Default USD.
Base price	Up to 4 decimal places.
Cost price	Admin-only. Up to 4 decimal places.
Minimum order quantity	The retail MOQ; B2B group multiplier is applied on top.
Weight (kg)	Used for shipping calculations.
Packaging notes	Max 500.
Product image	Drag-and-drop or click-to-upload primary image.

MEDIA

Upload additional images and set alt text, sort order, and the primary image. Actions per row: **Promote to primary** and **Remove**. Confirmations: "Remove this media entry? *url*", "Media attached.", "Primary image updated."

INVENTORY

- **Current state**: On hand, Reserved by cart / order, Available for new orders, Restock threshold, Last updated.
- **Adjust (signed delta)**: enter a positive or negative number ("+50" for restock, "-3" for loss) and an optional reason. Click **Apply adjustment**.
- **Overwrite (stock take)**: set the on-hand quantity and restock threshold outright. A confirmation warns "Overwrite on-hand quantity to *N*? This affects live sellable stock."

PRICING

Manages per-price-list tiers.

© Gadaa Istar Business Group S.C.

- Existing tiers are grouped by price list and show currency, INACTIVE flag if applicable, minimum quantity, and unit price.
- Under "Add / update tier" pick a price list, minimum quantity, and unit price. "Submitting a tier with an existing min-quantity replaces its price."
- The **Remove** action asks "Remove tier *min*+ @ *price* from *list*?"

VARIANTS

Each variant has its own SKU, name, optional price override, optional weight override, active flag, sort order, and an arbitrary set of attributes (key-value pairs). Actions: **Edit**, **Delete**, **Adjust inventory** (opens a small modal). Deletion is guarded by "Delete variant \"*name*\" (*sku*)? This removes the variant, its attributes, and its inventory row. This cannot be undone."

22.3 Archive

From the editor header, an **Archive** button changes the status to ARCHIVED. Confirmation: "Archive product \"*name*\"? It will disappear from the storefront (status → ARCHIVED). Historical orders keep working."

> **READ VS WRITE**
> Every admin can read product data. Write operations (create, update, archive, price tiers, variants) are restricted server-side to super-admins and product managers.

23. Price lists

URL: `/price-lists`

Price lists bind wholesale pricing to a customer group and currency. Each price list owns a set of (product × minimum quantity → unit price) entries. Retail customers without a group fall back to the base price.

23.1 Creating a price list

- Customer group (dropdown).
- Currency (ISO-3).
- Name.
- Effective from / Effective to (optional dates).
- "Active — customers in this group receive these prices." checkbox.

23.2 Editing

Editing is inline. The customer-group binding cannot be changed — the hint reads: "Bound to *code* — the customer group cannot be changed. If you need a different tier, delete and recreate."

23.3 Deleting

Confirmation: "Delete price list \"*name*\"? This will also remove all its entries. This cannot be undone."

© Gadaa Istar Business Group S.C.

24. Shipping methods

URL: `/shipping-methods`

Every rate card the storefront offers at checkout is stored here. The final price at checkout is calculated as:

```
shipping_cost = base_cost + per_kg_rate × cart_total_weight
```

24.1 Fields

- **Code**: `UPPER_SNAKE_CASE`, unique per currency.
- **Currency**: ISO-3.
- **Customer-facing name** and optional description.
- **Base cost** and **Per-kg rate**.
- **Min / Max transit days**.
- **Sort order**: lower shows first on the picker.
- "Active — offered to storefront customers." checkbox.

> **EDITING DOES NOT REWRITE HISTORY**
> "Historical orders that already used this method keep the snapshot at their placement time — changes here only affect quotes from now on."

© Gadaa Istar Business Group S.C.

25. Orders & refunds

URL: `/orders`

25.1 Orders list

- **Filters**: "Search by invoice number, email, or company…" and a status dropdown (All, Draft, Pending payment, Paid, Fulfilling, Shipped, Delivered, Cancelled, Partially refunded, Refunded).
- **Columns**: Invoice, Customer (name + email), Items count, Status (colour-coded pill), Total, Placed.

25.2 Order detail

URL: `/orders/<uuid>`

- **Header**: invoice number, placed / paid / cancelled timestamps, status badge.
- **Line items**: product name, SKU, variant, quantity, unit price, line total.
- **Totals**: Subtotal, Discount ("— *code*"), Tax, Shipping ("— *name* (*code*)"), Refunded, Total.
- **Customer**: name, email, company, phone.
- **Addresses**: Ship to and Bill to.
- **Notes**: customer notes and internal notes.
- **Move status** panel (see below).
- **Refund** panel (see below).
- **Status timeline** and **Refund history**.

25.3 Order-status state machine

Admins can only move an order along legal transitions:

From	To
DRAFT	PENDING_PAYMENT, CANCELLED
PENDING_PAYMENT	PAID, CANCELLED
PAID	FULFILLING, REFUNDED, CANCELLED
FULFILLING	SHIPPED, CANCELLED, REFUNDED
SHIPPED	DELIVERED, REFUNDED
DELIVERED	— (terminal)
CANCELLED, PARTIALLY_REFUNDED, REFUNDED	— (terminal)

The "Move status" panel exposes:

- Target status dropdown — only lists legal transitions.
- Note field — required when moving to CANCELLED or REFUNDED ("A note is required when moving an order to *status*.").
- **Move status** button (shows "Moving…" while in flight).

© Gadaa Istar Business Group S.C.

- Terminal-state lock message: "This order is in a terminal state (*status*) — no further transitions are allowed."

25.4 Refunds

Refunds are available on orders in PAID, FULFILLING, SHIPPED, DELIVERED, or PARTIALLY_REFUNDED.

- **Refund amount** — pre-filled with the remaining refundable balance.
- **Reason** — required, minimum 3 characters ("Please provide a reason (3+ chars) — it goes on the audit log.").
- **Manual refund** — checkbox that bypasses the payment gateway (only used when the money was already refunded out-of-band, e.g. by bank transfer).
- **Issue refund** — runs the refund; on success the message reads "Refunded *amount* — *gateway*." On gateway failure: "Refund attempt recorded, but the gateway rejected it: *error*."

> **RISK — MANUAL REFUNDS**
> "Manual refund (bypass gateway)" is powerful and must be reserved for reconciled, out-of-band refunds. It writes to the audit log but does not move any real money on its own.

26. Quotes

URL: `/quotes`

26.1 Quotes list

Filter by status (All, Draft, Submitted, Under review, Sent, Accepted, Converted, Rejected, Expired). Columns: Quote #, Customer, Items count, Status, Total, Created date.

26.2 Reviewing and sending a quote

URL: `/quotes/<uuid>`

1. The header shows the quote number, created date, and (once set) the "valid until" date.
2. Line items are listed with the customer's requested quantity and the currently-proposed unit price. Click the price to edit inline: "Enter a valid non-negative price."
3. Click **Start review** from the Review panel. The quote status becomes `UNDER_REVIEW`.
4. Use the **Send quote** panel to enter Shipping total, Tax total, "Valid for (days)" (default 30), and free-text "Notes to customer".
5. Click **Send to customer**. The status becomes `SENT` and the customer receives an email.

26.3 Rejecting

The **Reject** panel is available from `SUBMITTED` or `UNDER_REVIEW`. Enter a "Reason (sent to customer)" and click **Reject quote**.

© Gadaa Istar Business Group S.C.

26.4 Converting to an order

Once the customer accepts (status `ACCEPTED`), the **Convert to order** panel opens: select a shipping address and a shipping method and click **Convert**. The message on success is "Converted to order *invoice* (*total currency*)."

27. Customers

URL: `/customers`

27.1 Customer list

- Search: "Search by email, first / last name, or company…".
- Type filter: B2C + B2B, B2C (retail), B2B (wholesale).
- Status filter: Any status, Pending email verification, Pending B2B approval, Active, Suspended, Deactivated.
- **Reset** button clears all filters.
- Columns: Customer (display name + email, with an UNVERIFIED flag), Type, Status, Group, Currency, Signed up, Last login.

27.2 Customer detail

URL: `/customers/<id>`

The detail page pulls together everything about the account:

- **Identity**: customer ID, signed-up date, last login, email verification date, preferred currency and locale, orders placed.
- **Business profile** (B2B): company name, contact name, TIN, VAT number, and a link to the uploaded business licence file.
- **Addresses**: every address the customer has saved, with default markers.
- **Admin actions** panel.

27.3 Admin actions on a customer

APPROVING A B2B APPLICATION

For a customer with Pending B2B approval status, a highlighted panel reads: "Verify the business licence out-of-band, then approve to flip this account to ACTIVE." Clicking **Approve B2B** asks for confirmation: "Approve B2B application for *company*? Account will be flipped to ACTIVE and email verification force-completed."

MOVE STATUS

A target-status dropdown lists only legal transitions (PENDING_VERIFICATION → ACTIVE, ACTIVE → SUSPENDED / DEACTIVATED, etc.). Confirmation before submitting: "Move *email* to \"*label*\"? This logs them out of all devices (for SUSPENDED / DEACTIVATED)."

ASSIGN CUSTOMER GROUP

Choose a group from the dropdown and click **Save group**. Confirmation: "Move *email* to *group*?"

SESSION & RECOVERY TOOLS

- **Force verify email** — "Force-mark *email* as verified? Use this only when you've verified the address out-of-band."

© Gadaa Istar Business Group S.C.

- **Revoke all sessions** — "Revoke every live session for *email*? They'll be logged out on every device and must sign in again."
- **Send password reset** — "Email a password-reset link to *email*? Any previous reset links are invalidated, all live sessions are revoked, and the customer completes the reset themselves on the storefront."

> **RISK — "FORCE VERIFY" BYPASSES EMAIL POSSESSION**
> Force-verifying an email address bypasses the normal proof-of-email step. Only use it after independently confirming the address in a channel outside the platform (phone call, in-person, official business document). All actions are recorded in the audit log.

28. Customer groups

URL: `/customer-groups`

Customer groups drive B2B pricing tiers and per-tier minimum-order multipliers.

28.1 Fields

- **Code**: `UPPER_SNAKE_CASE`, unique.
- **Price tier**: RETAIL, WHOLESALE_T1, WHOLESALE_T2, VIP.
- **Display name**.
- **Description** (optional).
- **MOQ multiplier**: "1.000 = retail MOQ. 5.000 = 5× retail MOQ."
- Active checkbox — "new customers can be assigned to this group."

28.2 Deletion guardrail

A group cannot be deleted while customers are assigned: "\"*name*\" still has *N* customer(s) assigned. Reassign them to another group before deleting."

> **RETROACTIVITY**
> "Changes take effect on the next cart-add. Existing cart lines below the new effective MOQ are not retroactively rejected; the next add/update to that line will enforce the new rule."

29. Coupons

URL: `/coupons`

29.1 Fields

- **Code**: uppercase alphanumeric, max 64.
- **Discount type**: Percentage or Fixed amount.
- **Discount value** and **Currency** (ISO-3).

© Gadaa Istar Business Group S.C.

- **Min. subtotal**.
- **Free shipping** checkbox.
- **Max redemptions** (overall) and **Max per customer**.
- **Active** checkbox.
- **Starts at** and **Expires at** (datetime).
- Optional description.

29.2 List columns

Code, Discount (formatted), Currency, Min. subtotal, Free ship, Limits, Redeemed count, Active pill, Actions.

29.3 Deletion

Confirmation: "Delete coupon \"*code*\"? This cannot be undone."

30. CMS — pages & banners

30.1 CMS pages

URL: `/cms/pages`

- Fields: Slug (kebab-case, max 120), Title (max 200), Body HTML, SEO title, SEO description, Status (Draft / Published), Sort order.
- Rows show Slug, Title, Status pill (Draft / Published), Sort order, Updated timestamp.
- Deletion asks "Delete page \"*title*\" (*slug*)? This cannot be undone."
- Published pages appear on the storefront under `/pages/<slug>`.

30.2 CMS banners

URL: `/cms/banners`

- Fields: Placement (default `HOMEPAGE_HERO`, max 40), Title, Image URL (required, max 500), Alt text, Link URL, Active from / to (datetime), Sort order, Active checkbox.
- Rows show Placement, Title, a 60×30 thumbnail, Active / Off badge, Sort order.
- Deletion asks "Delete banner \"*title*\"? This cannot be undone."

> **BODY HTML IS RENDERED AS-IS**
>
> CMS Body HTML is sanitised on the storefront but any embedded third-party scripts, iframes, and links are still visible to customers. Review edits carefully before publishing.

31. Admin users

URL: `/admin-users`

This screen lists every account with back-office access.

© Gadaa Istar Business Group S.C.

31.1 Table columns

Email (with a "you" badge for the current user), Full name, Role pill, Status (ACTIVE / other), MFA (Enrolled / Pending), Last sign-in, Actions.

31.2 Reset MFA

Only a SUPERADMIN can reset another admin's MFA. Attempting to reset your own MFA is blocked with: "You can't reset your own MFA. Sign out and use the enrollment flow instead."

Confirmation for the reset:

> `Reset MFA for email? This wipes their TOTP secret and revokes every active session for that admin. They will be forced to re-enroll on their next sign-in.`

> **RISK — MFA RESET ABUSE**
>
> Resetting MFA on someone else's account is a privileged action. Ensure the request is legitimate (typically an out-of-band call with the account owner) before performing it. Every reset is written to the audit log with the initiating super-admin's identity.

© Gadaa Istar Business Group S.C.

APPENDIX A

Misuse scenarios & user-related risks

A short catalogue of misuse patterns that follow from the workflows described in this guide, with the controls the platform already provides and the operational guidance staff should follow.

© Gadaa Istar Business Group S.C.

Appendix A — Misuse scenarios & user-related risks

This appendix summarises the most relevant misuse scenarios and user-related risks for the Gadaa Istar platform. It is intentionally kept short and is designed to feed the platform's risk register and the periodic security & compliance review. Each row lists the **actor**, the **scenario**, the **potential impact**, and the **controls / mitigations** that are either already in place or should be enforced operationally.

© Gadaa Istar Business Group S.C.

A.1 Storefront (customer-facing) risks

Actor	Scenario	Impact	Controls / mitigations
Guest / attacker	Account-enumeration via login, forgot-password, or registration forms.	Discovery of registered email addresses (privacy leak).	Login errors are generic ("The email or password you entered is incorrect."). Forgot-password always returns success. Registration returns "already exists" — rate-limiting and reCAPTCHA recommended if abuse is observed.
Guest / attacker	Credential-stuffing against `/login`.	Account takeover.	8-character password minimum, per-account rate-limiting server-side, MFA on admin side only. Operational: monitor bulk 401 responses and enable IP-level throttling.
Guest / attacker	Order-reference enumeration on `/track-order`.	Attempted disclosure of order details.	Lookup requires both invoice number and matching email. Monitor failed lookups by IP.
Customer	Repeatedly abandoning checkouts to lock stock ("stock hoarding").	Legitimate buyers see items as unavailable; false low-stock alerts.	Reservations are released on order cancellation. Dashboard exposes "Abandoned orders" (> 1 hour) for review.
Customer	Coupon-code brute force at checkout.	Discovery of active promotional codes.	Coupon "Max redemptions" and "Max per customer" caps enforce natural limits. Consider rate-limiting apply-coupon calls at the gateway level.
B2C customer posing as B2B	Registering as a business with false company data to obtain wholesale pricing.	Revenue loss; misrepresentation.	B2B accounts start in Pending B2B approval and cannot buy at tier prices until an admin verifies the business licence out-of-band before clicking **Approve B2B**.
Customer	Chargeback fraud — disputing a legitimate paid order.	Financial loss; card-scheme penalties.	Payment is processed by CyberSource / MPGS (PCI DSS SAQ-A). Order status timeline, IP and address records feed dispute responses; use refund panel's Manual refund only when the money has already moved out-of-band.
Customer	Sharing a single account between many buyers of	Weak accountability; wholesale abuse.	Discourage in onboarding. Address book & order history

© Gadaa Istar Business Group S.C.

	the same company.		are per-account. Session revoke on password change enforces re-authentication.
Attacker with a stolen token	Reusing a leaked password-reset or verify-email link.	Account takeover.	Reset links expire in 30 minutes and are single-use; verification links expire in 60 minutes. Using a reset revokes all sessions.
Customer	Weak, reused, or shared password.	Account takeover.	8–128 character range enforced. Recommend adding password-breach checking and a strong-password policy in a future release.
Attacker (XSS)	Injecting HTML through free-text fields such as address, notes, or profile.	Session hijack; defacement.	Angular auto-escapes template bindings; CMS body HTML is sanitised. Do not disable sanitisation. Review any admin-authored CMS body before publishing.
Guest	Shared / public device leaves an active session behind.	Account takeover on the same device.	Session stored in `localStorage`. Encourage users to sign out on shared devices; password change revokes all sessions.

© Gadaa Istar Business Group S.C.

A.2 Back-office (admin-facing) risks

Actor	Scenario	Impact	Controls / mitigations
Malicious insider	Approving a fraudulent B2B account without verifying the licence.	Revenue loss; opens the door for wholesale-price fraud.	The "Approve B2B" confirmation reminds staff to verify the business licence out-of-band. Every approval is written to the audit log with the actor identity.
Malicious insider	Issuing "Manual refund (bypass gateway)" without the money actually moving.	Direct financial loss.	Reason required (min 3 chars) and audit-logged. Restrict Refund permission to trusted roles. Reconcile refunds daily against gateway statements.
Malicious insider	Editing prices, coupons, or shipping costs to favour a specific buyer.	Revenue leakage.	Historical orders keep the price snapshot at placement time. All price / coupon / shipping-method changes are audit-logged.
Malicious insider	Force-verifying a customer email without confirmation.	Account takeover of that customer email.	Explicit confirmation dialog and audit-log entry per action. Restrict the customer-detail write actions to authorised staff.
SUPERADMIN abusing MFA reset	Resetting another admin's MFA to impersonate them.	Full compromise of a peer admin account.	Only `SUPERADMIN` can reset another admin. Every reset is audit-logged and revokes the target's sessions immediately. Require two-person approval for MFA reset operationally.
Attacker	Phishing an admin's password + TOTP in real time.	Full back-office access.	MFA (SHA-1, 6 digits, 30 s window) mitigates static-password theft. Recommend FIDO2 for the future. Train staff to visit admin.gedaaistar.et directly (never via email links).
Attacker	Shoulder-surfing or session theft on shared workstations.	Order tampering, customer-data exposure.	Sign-out button in the top bar; every write operation is audit-logged. Enforce workstation lock policies operationally.
Admin	Publishing CMS Body HTML that contains third-party trackers or invisible content.	Legal risk (privacy), brand risk.	Body HTML is sanitised on the storefront but not stripped of tracking pixels; peer-review any CMS change before publishing.

© Gadaa Istar Business Group S.C.

Terminated employee	Continued admin access after termination.	Data exfiltration, order tampering.	Deactivate the admin user promptly (Admin users screen). Session tokens can be revoked out-of-band by resetting MFA.

A.3 Operational recommendations

1. Enable server-side rate-limiting on `/login`, `/forgot-password`, `/track-order`, `/coupons/apply`, and the guest cart endpoints.
2. Alert on any burst of failed `MFA_INVALID_CODE` or `INVALID_CREDENTIALS` errors from a single IP or account.
3. Require two-person approval for any **Reset MFA**, **Force verify email**, or **Manual refund** action — operationally, not just technically.
4. Review admin audit logs weekly for out-of-hours activity, refunds, price changes, and CMS publishing.
5. Reconcile refunds daily against the CyberSource / MPGS statements.
6. Provide staff with dedicated MFA devices and never share TOTP secrets.
7. Roll out password-breach checking and stronger password policy on the storefront in a future release.
8. Encourage retail customers to sign out on shared devices; consider a session-timeout banner.

© Gadaa Istar Business Group S.C.

Appendix B — Glossary

Term	Meaning
B2B	Business-to-Business. Wholesale buyers with tier pricing and MOQ multipliers.
B2C	Business-to-Consumer. Retail shoppers on the RETAIL group.
MOQ	Minimum Order Quantity — the smallest quantity that can be added to the cart for a product. Multiplied by the customer's group multiplier for B2B tiers.
Price list	A named collection of per-product minimum-quantity → price entries, tied to a customer group and currency.
Customer group	The category assigned to a customer (RETAIL, WHOLESALE_T1, WHOLESALE_T2, VIP). Drives which price list applies and the MOQ multiplier.
TOTP	Time-based One-Time Password. The 6-digit code generated by an authenticator app (Google Authenticator, Authy, 1Password). SHA-1 with a 30-second window.
MFA	Multi-Factor Authentication. Required for every admin session on Gadaa Istar.
SAQ-A	PCI DSS Self-Assessment Questionnaire A — the compliance level applicable when card data is handled entirely by a third-party (CyberSource / MPGS).
CyberSource	Third-party payment gateway operated by Visa. Handles card entry on its own page.
MPGS	Mastercard Payment Gateway Services. Alternate payment gateway used at checkout.
HS code	Harmonised System code — international customs classification.
TIN	Tax Identification Number, used on B2B accounts for VAT-compliant invoicing.
VAT	Value Added Tax. Ethiopian VAT (ERCA) rules apply to Ethiopian buyers.
SKU	Stock Keeping Unit. Uppercase identifier for a product or variant.
PDP	Product Detail Page — `/products/<slug>`.
Quote	A B2B negotiation record. Moves from DRAFT → SUBMITTED → UNDER_REVIEW → SENT → ACCEPTED → CONVERTED.
Terminal state	A status from which no further transitions are allowed (DELIVERED, CANCELLED, REFUNDED, PARTIALLY_REFUNDED).

© Gadaa Istar Business Group S.C.

Appendix C — URL & keyboard reference

C.1 Storefront routes (gedaaistar.et)

Path	Purpose	Access
`/`	Home page	Public
`/shop`	Catalog list	Public
`/shop/<category>`	Category-filtered catalog	Public
`/products/<slug>`	Product detail	Public
`/cart`	Shopping cart	Public (guest cart supported)
`/wishlist`	Wishlist (browser-local)	Public
`/track-order`	Public order tracking	Public
`/login`	Sign in	Guest only
`/register`	Registration (B2C / B2B)	Guest only
`/forgot-password`	Request password reset	Public
`/reset-password/<token>`	Complete password reset	Public (token-bound)
`/verify-email/pending`	"Check your inbox"	Public
`/verify-email/<token>`	Confirm email address	Public (token-bound)
`/account`	Profile	Signed-in customer
`/account/addresses`	Address book	Signed-in customer
`/account/orders`	Order history	Signed-in customer
`/account/orders/<uuid>`	Order detail	Signed-in customer
`/account/quotes`	Quote history	Signed-in customer
`/account/quotes/<uuid>`	Quote detail	Signed-in customer
`/checkout`	Checkout page	Signed-in customer
`/checkout/return`	Payment success / pending	Signed-in customer
`/checkout/cancel`	Payment cancelled / retry	Signed-in customer
`/about` , `/contact`	Shortcuts to CMS pages	Public
`/pages/<slug>`	CMS static page	Public

© Gadaa Istar Business Group S.C.

C.2 Admin routes (admin.gedaaistar.et)

Path	Purpose	Access
`/login`	Admin sign-in	Guest admin only
`/verify-mfa`	TOTP setup / verification	MFA challenge
`/dashboard`	KPIs, low stock, recent orders	Any admin
`/products`	Product list	Any admin (read)
`/products/new`	Create product	SUPERADMIN / product manager
`/products/<id>/details` … `/variants`	Product editor tabs	SUPERADMIN / product manager
`/price-lists`	Wholesale price lists	Any admin (read); write per role
`/shipping-methods`	Rate cards	Any admin
`/orders`, `/orders/<uuid>`	Order management & refunds	Any admin
`/quotes`, `/quotes/<uuid>`	Quote management	Any admin
`/customers`, `/customers/<id>`	Customer management	Any admin; some writes require role
`/customer-groups`	Price groups & MOQ multipliers	Any admin
`/coupons`	Discount codes	Any admin
`/cms/pages`, `/cms/banners`	CMS content	Any admin
`/admin-users`	Admin accounts, MFA status	Any admin (view); SUPERADMIN to reset MFA

C.3 Keyboard hints

- `Enter` submits the storefront search box from anywhere in the header.
- `Tab` / `Shift`+`Tab` cycles through form fields in the checkout, address book, and admin forms.
- `Esc` closes admin modals such as the refund dialog and variant editor.

> **FEEDBACK**
>
> Please send suggestions for improving this guide to the operations team. Every misuse scenario reported by a real user makes the platform safer.

© Gadaa Istar Business Group S.C.